

SignShield

AI 签名前风险解释层

黑客松选题方案 / Hackathon Project Brief

一句话定位

SignShield 是一个面向普通 Web3 钱包用户的 pre-signature risk copilot：在用户点击 Confirm / Sign 之前，通过交易模拟、calldata 解码、合约透明度检查、第三方风险情报和 AI 解释，把陌生智能合约交互的风险结构翻译成人话。

核心原则：Simulation first, AI second. 先用链上模拟和数据产生事实，再让 AI 解释。

目录

1. 项目定位与用户问题
2. 使用场景与 MVP 边界
3. 核心产品流程
4. 风险分析模块
5. 未开源合约的处理策略
6. 第三方黑名单与粗筛情报
7. 技术架构与 MCP / Skills 设计
8. 风险评分与输出格式
9. 竞品调研与差异化
10. Demo 设计与开发排期
11. 参考资料

1. 项目定位与用户问题

SignShield 的目标不是替代企业级安全审计，也不是发现所有智能合约漏洞。它解决的是普通钱包用户在陌生 dApp 前最常见、最直接的问题：这笔交易/签名到底会不会害我？

项目定义

一个“签名前风险解释层”：在用户点击 Confirm / Sign 之前，解释交易会做什么、哪些资产或权限会受影响、对方合约/网站是否可信、风险为什么高，以及用户应该拒绝、继续、降低授权额度还是使用 burner wallet。

不是做什么

- 不是完整合约审计平台。
- 不是 AML / 合规风控系统。
- 不是链上攻击监控平台。
- 不是只查黑名单的浏览器插件。

真正要做什么

- 在用户签名前 5 秒，把复杂的链上风险翻译成成人话。
- 把 calldata、simulation、source verification、proxy、approval、domain reputation、blacklist signals 聚合成结构化风险报告。
- 让普通用户知道“为什么危险”，而不是只看到红灯。

2. 使用场景与 MVP 边界

目标用户

- 普通钱包用户：不熟悉 approve、permit、proxy、calldata 和签名权限。
- DeFi / NFT 用户：频繁与陌生合约、空投、mint、交易市场交互。
- 钱包和 dApp 开发者：需要一个可组合的签名前风险分析工具。

核心场景

- 用户访问陌生 dApp。
- dApp 弹出交易或签名请求。
- SignShield 拦截或接收 chainId、from、to、data、value、origin。
- 系统完成交易模拟、calldata 解码、合约透明度和信誉检查、第三方粗筛。
- 系统给出风险等级、证据链和建议。

MVP 形态

黑客松建议先做 MCP / Skills 工具组 + 简单钱包确认页 Demo。不要一开始做完整钱包插件或 MetaMask Snap，因为浏览器注入、钱包兼容和审核流程会消耗大量时间。

形态	推荐度	说明
MCP / Skills 工具组	高	最快落地；可被钱包、agent、dApp 调用。

简单钱包确认页 Demo	高	可清楚展示用户体验，不依赖真实钱包接入。
浏览器插件	中	更贴近真实产品，但兼容性成本较高。
MetaMask Snap	中低	产品形态强，但开发、权限和审核成本较高。

3. 核心产品流程

建议把系统设计成“事实层 -> 规则层 -> 解释层”，避免让 LLM 直接猜测链上行为。



输入

```
{
  "chainId": 1,
  "from": "0xUser",
  "to": "0xContract",
  "data": "0x...",
  "value": "0",
  "origin": "https://unknown-dapp.example"
}
```

输出

```
{
  "riskLevel": "HIGH",
  "summary": "This transaction grants unlimited USDC approval to an unverified contract.",
  "assetImpact": [{"type": "ERC20_APPROVAL", "token": "USDC", "spender": "0x...", "amount": "unlimited"}],
  "riskFactors": ["Unlimited ERC20 approval", "Spender contract source is unverified", "Contract deployed less than 24 hours ago"],
  "recommendation": "Reject this transaction or reduce the approval amount."
}
```

4. 风险分析模块

4.1 Calldata 解码

识别用户即将调用的函数和参数。即使合约没有开源源码，也可以通过 function selector、ABI 数据库和标准接口识别高风险操作。

高风险调用	解释
approve(address,uint256)	授权 spender 花费 ERC20；无限授权是高风险。
setApprovalForAll(address,bool)	允许 operator 转移某 NFT collection 下所有 NFT。
permit / Permit2	签名型授权，用户可能没有意识到会授予资产支配权。
transfer / transferFrom	直接资产转移或代扣。
multicall / execute	可能把多个动作包在一起，需要递归解析。
delegatecall / arbitrary call	高级风险信号，可能执行外部逻辑。

4.2 交易模拟

交易模拟是 SignShield 的事实层。它负责回答：如果用户现在签下这笔交易，链上状态会发生什么变化？

模拟字段	用途
ETH / native balance diff	判断是否有 ETH 流出。
ERC20 balance diff	判断 token 是否流出或进入。
NFT ownership diff	判断 NFT 是否被转移。
allowance changes	判断授权额度是否被改变。
operator approval changes	判断是否 setApprovalForAll。
internal calls	识别内部调用了哪些合约。
events/logs	辅助还原行为和资产变化。
revert reason	提示交易是否失败及失败原因。

推荐优先接 Tenderly Simulation API：它支持通过 RPC/API 进行单笔交易模拟，官方文档明确说明 dApp 和钱包可以用它 dry-run 用户交易，并预览交易执行结果和详细的 balance / asset changes。

4.3 合约透明度与信誉

- 源码是否在 Etherscan / Blockscout 验证。
- 是否 proxy, implementation 是否验证。
- 合约部署时间、deployer、历史交互数量。
- 是否有 known protocol label 或 phishing warning label。
- deployer 是否创建过大量短命或可疑合约。

4.4 网站与来源分析

- origin domain 是否命中 Web3 phishing denylist。
- 是否 typosquatting 或新注册域名。
- 域名是否与合约 owner / deployer / known protocol 有关联。
- 前端描述是否与 calldata / simulation 结果一致。

5. 未开源合约的处理策略

核心判断

合约未在 Etherscan / Blockscout 验证源码，不等于一定恶意，但应显著提高风险等级，并切换到 bytecode + simulation + reputation fallback analysis。

为什么危险

- 无法确认合约真实逻辑是否和网站描述一致。
- 无法确认是否存在 owner/admin/upgrader 后门。

- 无法确认 proxy implementation 是否可信。
- 交易模拟只能证明当前状态下这次调用的结果，不能证明没有隐藏路径。

Fallback 分析模式

- 用 4byte / OpenChain / 本地 selector 库解码 calldata。
- 用 Tenderly 或 Anvil 模拟资产变化、授权变化和内部调用。
- 分析 bytecode 是否包含 proxy、DELEGATECALL、SELFDESTRUCT、minimal clone 等模式。
- 检查部署时间、deployer 历史、交互数量、标签和第三方情报。

组合场景	建议风险等级
未开源，但知名协议地址、大量历史交互、无资产授权	Medium
未开源 + 新部署 + 低交互 + 需要授权	High
未开源 + 无限 ERC20 授权 / setApprovalForAll / Permit2	Critical
未开源 + proxy implementation 未验证	High / Critical
未开源 + simulation 显示资产流出	Critical

6. 第三方黑名单与粗筛情报

第三方情报的定位是“粗筛”和“证据补充”，不能替代 simulation。设计上应采用多源聚合：命中情报源只是加权信号，最终风险由 threat intel + simulation + contract transparency + approval diff 共同决定。

推荐优先接入

优先级	来源	用途	MVP 价值
1	MetaMask eth-phishing-detect	Web3 钓鱼域名 denylist	开源、直接可用，适合查 origin domain。
2	GoPlus Security API	Token、地址、dApp、NFT、approval 风险	覆盖面广，适合 hackathon 快速集成。
3	Tenderly Simulation	交易模拟、资产变化、内部调用	作为事实层，不是黑名单。
4	PhishTank / OpenPhish	通用钓鱼域名库	补充 Web2 phishing 风险。
5	OFAC SDN / sanctions data	制裁与合规风险	命中应提示 compliance risk。

情报源分层

类别	可用来源	用于判断
域名钓鱼库	MetaMask eth-phishing-detect, PhishTank, OpenPhish, ChainPatrol/ScamSniffer	origin 是否是钓鱼站、drainer 站或仿冒域名。
地址/合约风险库	GoPlus, Chainabuse, ScamSniffer, Blockaid/Blowfish API (如有)	spender、operator、contract 是否已知可疑。
Token 风险库	GoPlus Token Security, TokenSniffer/honeypot 类工具	honeypot、税率异常、owner 权限、可卖出性。
模拟服务	Tenderly, Anvil fork, Hardhat Network	资产变化、授权变化、内部调用。
合规名单	OFAC SDN 等	sanctions/compliance risk，与技术恶意分开呈现。
浏览器标签	Etherscan, Blockscout, Arkham/Nansen/Dune labels (视 API 可得性)	known protocol、phishing、fake token、contract creator。

聚合输出示例

```
{
  "address": "0x...",
  "domain": "claim-example.xyz",
  "matches": [
    {"source": "metamask_eth_phishing_detect", "type": "domain_phishing", "severity": "critical", "confidence": 0.95},
    {"source": "goplus", "type": "token_risk", "severity": "high", "confidence": 0.75},
    {"source": "ofac", "type": "sanctions", "severity": "critical", "confidence": 1.0}
  ],
  "aggregateRisk": "critical"
}
```

7. 技术架构与 MCP / Skills 设计

SignShield 最适合拆成可组合的 MCP tools / skills，而不是一个封闭插件。这样钱包、dApp、agent、浏览器插件都可以调用同一套风险分析能力。

Tool / Skill	职责
decode_calldata	识别函数 selector、参数、标准 approve / permit / multicall 等。
simulate_transaction	调用 Tenderly 或 Anvil，返回资产变化、授权变化、内部调用。
scan_approval_risk	识别 unlimited approval、Permit2、setApprovalForAll、陌生 spender。
check_contract_reputation	查源码验证、部署时间、deployer、标签、历史交互。
inspect_proxy	识别 proxy 和 implementation 验证状态。
check_domain_reputation	查 Web3 phishing denylist、通用 phishing、域名可疑度。
threat_intel_aggregate	聚合 GoPlus、MetaMask、OFAC、Chainabuse 等粗筛信号。
risk_score	将事实和情报转成结构化分数、等级和 policy。
generate_user_warning	用普通语言解释风险结构和建议动作。

推荐技术栈

层级	推荐
前端 Demo	Next.js / React 钱包确认页 mock。
后端	Node.js / Python API server，暴露 MCP tools。
模拟	Tenderly 默认；Anvil fork 作为开源 fallback。
链上数据	Etherscan / Blockscout / RPC。
Selector 解码	4byte / OpenChain / 本地 signature DB。
情报源	MetaMask eth-phishing-detect, GoPlus, PhishTank/OpenPhish, OFAC, Chainabuse。
AI 解释	LLM 只解释结构化事实，不编造链上结论。

8. 风险评分与输出格式

评分规则示例

- +60 OFAC / sanctions hit
- +50 Web3 phishing domain hit
- +45 known drainer / scam address hit
- +40 setApprovalForAll(true)

- +40 deployer linked to suspicious contracts
- +35 multiple abuse reports
- +30 unlimited ERC20 approval
- +30 GoPlus high-risk token / contract flag
- +25 proxy implementation unverified
- +20 contract source unverified
- +20 contract deployed < 7 days
- +15 generic phishing database hit

0-24 Low
25-49 Medium
50-74 High
75+ Critical

用户解释模板

High Risk

This transaction does not simply claim a reward. It grants an unknown contract unlimited permission to spend your USDC.

- Why this is risky:
- 1. The spender contract has not verified its source code.
 - 2. The approval amount is unlimited.
 - 3. The contract was deployed recently.
 - 4. The website is not linked to a known protocol.

Recommendation:
Reject this transaction, or reduce the approval amount to only what you need.

为了避免误导用户，输出中应明确区分 technical risk、scam/phishing risk 和 compliance risk。例如 OFAC 命中是合规风险，不等同于合约技术恶意。

9. 竞品调研与差异化

该赛道已有成熟公司和浏览器插件，但它们多偏企业 API、黑名单/拦截或封闭式钱包集成。SignShield 的机会是做一个轻量、可组合、可解释、面向陌生交互的 pre-signature risk copilot。

产品	定位	强项	SignShield 差异化
Blockaid	企业级 onchain security / trust layer	大规模钱包/dApp/机构集成，实时威胁情报。	更轻量、开源友好、适合个人用户和黑客松 demo。
Blowfish	钱包交易/签名安全 API	交易预览、message/transaction simulation、scam list。	强调 MCP/Skills 可组合和 AI 解释层。
Pocket Universe	浏览器插件，签名前资产变化预览	消费级体验，清晰 warnings。	更透明地展示证据链和可调试的结构化风险对象。
Scam Sniffer	Web3 anti-scam / phishing 情报	drainer、钓鱼站点情报。	不仅依赖黑名单，还分析未知合约和交易模拟结果。
Wallet Guard	曾经的开源浏览器安全插件，已 sunset	human-readable transaction、scam detection。	借鉴交互形态，但优先做工具化 MCP/Skills，而非完整插件运营。

核心差异化

- Explainable Risk：不仅给红灯，还解释风险证据、资产影响和建议动作。
- Unknown Contract Analysis：对未入库、未开源、低信誉合约也能通过 fallback analysis 给出风险结构。
- Simulation First, AI Second：交易模拟和链上数据是事实层，AI 只负责解释。
- MCP / Skills 化：可被钱包、dApp、agent、浏览器插件复用，不是封闭产品。

10. Demo 设计与开发排期

三条 Demo 故事线

Demo	场景	系统提示
Demo 1: 无限 ERC20 授权	用户以为在 claim 空投，实际 calldata 是 approve(spender, uint256.max)。	这不是领取奖励，而是在授权陌生合约无限转走你的 USDC。
Demo 2: NFT 全集授权	用户以为在 verify wallet，实际是 setApprovalForAll(operator, true)。	该操作允许 operator 转移你这个 NFT collection 下的所有 NFT。
Demo 3: 未验证源码合约	合约未验证源码、新部署、无协议标签，simulation 显示资产流出。	源码不可读且资产会流出，建议拒绝或使用 burner wallet。

48 小时开发排期

阶段	目标
0-6 小时	确定 EVM-only 范围；完成输入/输出 schema；搭建 wallet confirmation mock UI。
6-18 小时	接入 calldata 解码、Tenderly simulation、Etherscan/Blockscout 基础合约信息。
18-30 小时	接入 MetaMask eth-phishing-detect、GoPlus、OFAC/PhishTank 可选 adapter；完成 risk scoring。
30-40 小时	完成 AI explanation、三条 demo case、结构化 JSON 和用户 warning card。
40-48 小时	打磨 pitch、录制 demo、准备 fallback 数据，避免现场 API 不稳定。

最终 Pitch

英文版

SignShield is an AI pre-signature risk copilot for Web3 wallets. It analyzes unknown smart contract interactions before users sign by decoding calldata, simulating transaction effects, checking contract transparency and reputation, aggregating third-party risk intelligence, detecting risky approvals, and explaining the risk in plain language.

中文版

SignShield 是一个面向 Web3 钱包的 AI 签名前风险解释层。它会在用户签名或发送交易之前，解析 calldata、模拟交易结果、检查合约透明度和链上信誉、聚合第三方风险情报、识别危险授权，并用普通用户能理解的语言解释风险结构。

11. 参考资料

1. MetaMask eth-phishing-detect: GitHub repository. List of malicious domains targeting Web3 users; blocking policy includes impersonation and collection of signing keys.
<https://github.com/MetaMask/eth-phishing-detect>
2. GoPlus Security: Token Security API documentation. <https://docs.gopluslabs.io/reference/token-security-api>
3. Tenderly Documentation: Single Simulations; supports single transaction simulations via RPC/API and transaction previews with balance and asset changes. <https://docs.tenderly.co/simulations/single-simulations>
4. Blowfish: Proactive defense for web3 wallets; transaction and message signing security, Dapp security, Verify/scam list, simulation APIs. <https://blowfish.xyz/>
5. Blockaid: Onchain security / trust layer for wallets, dApps, institutions and exchanges.
<https://www.blockaid.io/>
6. Pocket Universe: Browser extension for signing-time asset protection and clear malicious transaction warnings. <https://www.pocketuniverse.app/>
7. Wallet Guard: Former open-source browser extension for human-readable transactions and scam detection; sunset information available on the official site. <https://www.walletguard.app/>